

Projet Électif –CYBER_ FINANCE

RAPPORT TECHNIQUE :

Conception et mise en œuvre d'une plateforme
Centralisée de supervision et de monitoring de la sécurité
Pour une infrastructure bancaire hébergée dans le Cloud

POC – Mise en place d'un SOC (Security Operations Center)

Établissement	ECE
Module	Projet Électif CYBER_FINANCE
Encadrant	M. Konate Dotemin
Technologie	VMware Wazuh Zabbix Grafana pfSense
Année académique	2025 – 2026

Rédigé par :

- DEFFO FOKOU FRANCK EMERITE
- SOPPO BWAME ADÈLE ALINE JOHANNE MARION
- BOREL NGHOPONG LONTSI
- JEMIMA KABORE

Table des matières

Table des matières	2
Résumé exécutif	5
1. Introduction	6
1.1 Contexte général	6
1.2 Objectifs du projet.....	6
1.3 Périmètre du POC	6
2. État de l'art et cadre réglementaire.....	8
2.1 La cybersécurité dans le secteur bancaire.....	8
2.2 Le concept de SOC (Security Operations Center)	8
2.3 SIEM et supervision : concepts clés	8
2.4 Cadre réglementaire applicable	9
2.4.1 DORA – Digital Operational Resilience Act	9
2.4.2 PCI-DSS – Payment Card Industry Data Security Standard.....	9
2.4.3 RGPD – Règlement Général sur la Protection des Données.....	9
2.4.4 Directives de l'ACPR et de la BCE	9
3. Problématique et enjeux	11
3.1 Formulation de la problématique	11
3.2 Enjeux identifiés	11
3.2.1 Enjeux opérationnels.....	11
3.2.2 Enjeux de sécurité.....	11
3.2.3 Enjeux réglementaires.....	11
3.3 Analyse des risques	11
4. Architecture de la solution	13
4.1 Vue d'ensemble de l'architecture	13
4.2 Environnement de virtualisation – VMware	13
4.3 Description des machines virtuelles.....	13
4.3.1 VM1 – Poste client Windows	14
4.3.2 VM2 – Serveur Alma (Centre SOC).....	14
4.3.3 VM3 – Serveur de base de données	14
4.3.4 VM4 – Serveur web applicatif.....	14
4.3.5 VM5 – Poste administrateur	15
4.4 Sécurité réseau – pfSense	15
5. Outils déployés et configuration	16
5.1 Wazuh – SIEM et détection d'intrusions.....	16
5.1.1 Présentation de Wazuh	16
5.1.2 Fonctionnalités utilisées dans ce projet.....	16
5.1.3 Architecture de déploiement Wazuh.....	16

5.2 Zabbix – Supervision d'infrastructure	17
5.2.1 Présentation de Zabbix	17
5.2.2 Métriques supervisées	17
5.2.3 Système d'alertes Zabbix	17
5.3 Grafana – Visualisation et tableaux de bord	18
5.3.1 Présentation de Grafana	18
5.3.2 Tableaux de bord configurés	18
6. Réalisation du POC.....	19
6.1 Démarche de déploiement.....	19
6.2 Difficultés rencontrées et solutions apportées.....	19
6.2.1 Problème 1 – Agents Wazuh non connectés.....	19
6.2.2 Problème 2 – Serveurs affichés offline dans Grafana.....	20
6.2.3 Problème 3 – Conflits d'identifiants suite au clonage de VMs.....	20
7. Tests de sécurité et validation du POC	21
7.1 Méthodologie de test	21
7.2 Test 1 – Attaque par force brute SSH.....	21
7.2.1 Description du scénario.....	21
7.2.2 Exécution du test.....	21
7.2.3 Résultats et analyse	21
7.3 Test 2 – Surveillance d'intégrité des fichiers (FIM).....	22
7.3.1 Description du scénario.....	22
7.3.2 Exécution du test.....	22
7.3.3 Résultats et analyse	22
7.4 Test 3 – Simulation d'attaque web	23
7.4.1 Description du scénario.....	23
7.4.2 Exécution du test.....	23
7.4.3 Résultats et analyse	23
8. Résultats et bilan du POC.....	24
8.1 Synthèse des résultats obtenus.....	24
8.2 Indicateurs de performance clés.....	24
8.3 Valeur ajoutée de la solution.....	24
8.3.1 Réduction du risque financier	24
8.3.2 Conformité réglementaire.....	25
8.3.3 Retour sur investissement (ROI)	25
9. Limites, améliorations et perspectives.....	26
9.1 Limites du POC	26
9.2 Axes d'amélioration à court terme.....	26
9.3 Perspectives à moyen terme	26
9.4 Scalabilité de l'architecture	27

10. Conclusion	28
11. Glossaire.....	29
12. Bibliographie et références.....	31
12.1 Réglementation et normes.....	31
12.2 Documentation technique	31
12.3 Publications et rapports	31

Résumé exécutif

Ce rapport présente la conception et la réalisation d'un Proof of Concept (POC) dans le cadre du projet électif FINANCE_CYBER. L'objectif central est de démontrer la faisabilité d'une plateforme centralisée de supervision et de monitoring de la sécurité adaptée à une infrastructure bancaire hébergée dans un environnement de virtualisation.

Face à la recrudescence des cyberattaques ciblant le secteur financier et aux exigences réglementaires croissantes (DORA, PCI-DSS, RGPD), les établissements bancaires doivent impérativement disposer d'une capacité de détection et de réponse aux incidents en temps réel. Ce projet répond à cette problématique en s'appuyant sur une stack technologique open source éprouvée : Wazuh (SIEM/IDS), Zabbix (supervision d'infrastructure) et Grafana (visualisation).

L'environnement de déploiement est un Cloud privé simulé sur VMware, hébergeant cinq machines virtuelles représentant les composantes typiques d'un système d'information bancaire : un poste client Windows, un serveur web applicatif, un serveur de base de données, un poste d'administration et un serveur central SOC.

Les résultats obtenus démontrent la capacité du système à détecter des attaques simulées (brute force SSH, tentatives d'intrusion web, altération de fichiers système), à centraliser les journaux d'événements et à les restituer sous forme de tableaux de bord opérationnels. Ce POC constitue un démonstrateur crédible d'une architecture SOC pouvant être déployée dans un contexte bancaire réel.

1. Introduction

1.1 Contexte général

Le secteur bancaire et financier est l'un des secteurs les plus ciblés par les cyberattaques à l'échelle mondiale. Selon les données publiées par l'Agence de l'Union européenne pour la cybersécurité (ENISA), les établissements financiers subissent en moyenne 300 fois plus d'attaques informatiques que les entreprises d'autres secteurs. Les conséquences peuvent être dramatiques : pertes financières directes, atteinte à la réputation, sanctions réglementaires et perturbation des services aux clients.

Dans ce contexte, la transformation numérique accélérée des banques, migration vers le Cloud, adoption de l'open banking, généralisation des applications mobiles a considérablement élargi la surface d'attaque. Les environnements informatiques bancaires sont désormais distribués, hybrides, et exposés à des menaces de plus en plus sophistiquées : ransomwares, attaques de la chaîne d'approvisionnement (supply chain attacks), phishing ciblé, compromission de comptes à privilèges.

La mise en place d'un Security Operations Center (SOC), centre de surveillance et de réponse aux incidents de sécurité, représente une réponse institutionnelle à ces défis. Un SOC centralise la collecte des événements de sécurité, leur analyse et la coordination des actions de remédiation. Il constitue un pilier fondamental de la posture de cybersécurité d'une organisation financière.

1.2 Objectifs du projet

Ce projet électif FINANCE_CYBER vise à concevoir et déployer un POC d'une plateforme SOC adaptée à une infrastructure bancaire Cloud. Les objectifs pédagogiques et techniques sont les suivants :

- Identifier et analyser une problématique réelle de cybersécurité dans le secteur financier.
- Concevoir une architecture de supervision avec une approche sécurité by design.
- Déployer et configurer des outils open source de niveau professionnel dans un environnement virtualisé.
- Réaliser des tests de sécurité simulés et valider la capacité de détection du système.
- Produire un argumentaire technique et stratégique à destination d'un comité de direction ou d'un investisseur.

1.3 Périmètre du POC

Le périmètre de ce proof of concept couvre les éléments suivants :

- Déploiement d'une infrastructure bancaire simulée sur VMware (5 machines virtuelles).
- Mise en place d'une solution de supervision de performance (Zabbix).

- Intégration d'un SIEM open source pour la centralisation et l'analyse des journaux de sécurité (Wazuh).
- Configuration de tableaux de bord de visualisation en temps réel (Grafana).
- Sécurisation et segmentation réseau (pfSense).
- Réalisation de trois scénarios d'attaque pour valider la détection.

En revanche, le périmètre exclut : le déploiement en production sur un Cloud public, l'intégration d'un véritable système bancaire Core Banking, et la mise en œuvre de procédures de réponse aux incidents (SOAR).

2. État de l'art et cadre réglementaire

2.1 La cybersécurité dans le secteur bancaire

Le secteur financier fait face à un paysage de menaces particulièrement hostile. Les cyberattaques contre les banques peuvent prendre de nombreuses formes, allant du phishing ciblé (spear phishing) contre des employés à hauts privilèges, aux attaques de type SWIFT (comme les 81 millions de dollars dérobés à la Banque centrale du Bangladesh en 2016), en passant par les ransomwares qui paralysent les systèmes.

La digitalisation des services financiers a également engendré de nouveaux vecteurs d'attaque. Les API bancaires ouvertes (Open Banking), les applications mobiles et les plateformes de paiement en ligne constituent autant de points d'entrée potentiels pour des acteurs malveillants. La gestion de ces risques nécessite une approche systématique et centralisée.

2.2 Le concept de SOC (Security Operations Center)

Un Security Operations Center est une unité organisationnelle et technique chargée de surveiller, détecter, analyser et répondre aux incidents de cybersécurité en temps réel. Il repose sur trois piliers fondamentaux :

- Les personnes (analysts SOC, CISO, équipes de réponse à incident).
- Les processus (procédures de triage, d'escalade, de remédiation).
- La technologie (SIEM, IDS/IPS, outils de threat intelligence, EDR).

Dans une banque, le SOC assume un rôle critique : il est le premier point de détection des tentatives d'intrusion, des mouvements latéraux au sein du réseau interne, des exfiltrations de données et des anomalies comportementales. Il permet de réduire significativement le Mean Time to Detect (MTTD) et le Mean Time to Respond (MTTR), deux indicateurs clés de la maturité cyber.

2.3 SIEM et supervision : concepts clés

Les outils qui constituent la colonne vertébrale technologique d'un SOC sont principalement :

Le SIEM (Security Information and Event Management) : il agrège les journaux d'événements provenant de l'ensemble des composantes du système d'information (serveurs, équipements réseau, applications), les normalise et les corrèle pour détecter des schémas d'attaque. Wazuh est une solution SIEM open source qui intègre également des capacités d'IDS (Intrusion Detection System) et de File Integrity Monitoring.

Les outils de supervision d'infrastructure : ils mesurent en temps réel les performances des systèmes (CPU, mémoire, disque, réseau) et génèrent des alertes en cas d'anomalie. Zabbix est l'un des outils de monitoring les plus déployés dans le monde, particulièrement dans les environnements critiques.

Les outils de visualisation : Grafana permet de créer des tableaux de bord dynamiques en interrogeant les sources de données (Zabbix, Elasticsearch, Prometheus, etc.). Il facilite la prise de décision en synthétisant des volumes importants de données en indicateurs visuels clairs.

2.4 Cadre réglementaire applicable

L'architecture proposée s'inscrit dans un cadre réglementaire exigeant. Les principales réglementations applicables au secteur bancaire européen sont :

2.4.1 DORA – Digital Operational Resilience Act

Le règlement européen DORA (EU 2022/2554), entré en application en janvier 2025, impose aux établissements financiers de l'Union européenne des exigences strictes en matière de résilience opérationnelle numérique. Il impose notamment :

- La mise en place d'un cadre de gestion du risque TIC (Technologies de l'Information et de la Communication).
- La déclaration obligatoire des incidents ICT majeurs auprès des autorités de supervision.
- Des tests de résilience opérationnelle numérique, incluant des tests d'intrusion.
- La gestion du risque lié aux prestataires tiers (Cloud, SaaS).

Le SOC mis en place dans ce projet répond directement aux exigences DORA relatives à la surveillance continue, à la détection des incidents et à la traçabilité des événements de sécurité.

2.4.2 PCI-DSS – Payment Card Industry Data Security Standard

La norme PCI-DSS (version 4.0 depuis 2022) impose des contrôles de sécurité stricts à toute organisation qui traite des données de cartes de paiement. Parmi les exigences directement adressées par ce projet :

- Exigence 10 : Journaliser et surveiller tous les accès aux composants système et aux données de titulaires de cartes.
- Exigence 11 : Tester régulièrement la sécurité des systèmes et des réseaux.
- Exigence 12 : Maintenir une politique de sécurité de l'information pour l'ensemble du personnel.

2.4.3 RGPD – Règlement Général sur la Protection des Données

Le RGPD (EU 2016/679) impose aux banques de protéger les données personnelles de leurs clients. L'article 32 exige la mise en place de mesures techniques appropriées pour garantir un niveau de sécurité adapté au risque, incluant la capacité de détecter rapidement toute violation de données. Le SIEM Wazuh, par sa capacité à détecter les accès non autorisés et les anomalies comportementales, contribue directement à cette conformité.

2.4.4 Directives de l'ACPR et de la BCE

L'Autorité de Contrôle Prudentiel et de Résolution (ACPR) et la Banque Centrale Européenne (BCE) publient des guides et des recommandations en matière de cybersécurité pour les établissements financiers. Ces textes insistent sur la nécessité d'une surveillance continue, d'une capacité de réponse aux incidents et d'une gouvernance de la cybersécurité au plus haut niveau.

3. Problématique et enjeux

3.1 Formulation de la problématique

La problématique centrale de ce projet est la suivante :

Problématique

Comment concevoir une solution centralisée permettant de superviser efficacement une infrastructure bancaire hébergée dans le Cloud, tout en assurant la surveillance de la performance, de la disponibilité et de la sécurité des systèmes, dans un contexte contraint par des exigences de fiabilité, de traçabilité et de conformité réglementaire ?

3.2 Enjeux identifiés

Cette problématique se décline en plusieurs enjeux opérationnels, stratégiques et réglementaires :

3.2.1 Enjeux opérationnels

- Garantir la disponibilité 24h/24 des services bancaires (conformément aux SLA bancaires typiques de 99,99%).
- Détecter rapidement toute dégradation de performance pouvant impacter l'expérience client.
- Centraliser les informations de supervision pour permettre une réaction rapide des équipes IT.
- Réduire le Mean Time to Detect (MTTD) et le Mean Time to Respond (MTTR).

3.2.2 Enjeux de sécurité

- Détecter les tentatives d'intrusion sur les serveurs critiques (base de données, application web).
- Surveiller l'intégrité des fichiers système pour prévenir les modifications non autorisées.
- Identifier les comportements anormaux indicateurs d'une compromission (mouvements latéraux, escalade de privilèges).
- Maintenir une traçabilité complète des événements pour les besoins d'audit et d'investigation forensique.

3.2.3 Enjeux réglementaires

- Répondre aux exigences DORA de surveillance continue et de déclaration des incidents.
- Satisfaire aux exigences PCI-DSS de journalisation et de surveillance des accès.
- Maintenir les conditions techniques permettant la démonstration de conformité RGPD.

3.3 Analyse des risques

L'analyse des risques liés à l'absence d'une plateforme de supervision dans un contexte bancaire Cloud est la suivante :

Menace	Probabilité	Impact	Criticité
Attaque brute force SSH	Élevée	Critique	Maximale
Exfiltration de données via API	Moyenne	Critique	Élevée
Ransomware sur serveur de BDD	Moyenne	Catastrophique	Maximale
Phishing ciblé (employés)	Très élevée	Élevé	Élevée
Attaque DDoS sur serveur web	Moyenne	Élevé	Élevée
Compromission de compte admin	Faible	Catastrophique	Élevée
Modification non autorisée de fichiers	Moyenne	Critique	Élevée
Indisponibilité service (panne)	Moyenne	Élevé	Modérée

4. Architecture de la solution

4.1 Vue d'ensemble de l'architecture

L'architecture mise en place s'articule autour d'un modèle de supervision à plusieurs niveaux, déployé sur un environnement de virtualisation VMware. Ce choix reflète la réalité des banques qui s'appuient sur des infrastructures virtualisées ou Cloud pour héberger leurs systèmes d'information.

L'architecture est organisée en plusieurs couches fonctionnelles complémentaires :

- Couche infrastructure : machines virtuelles représentant les composantes d'un SI bancaire.
- Couche réseau et sécurité périmétrique : filtrage et segmentation avec pfSense.
- Couche supervision technique : monitoring des performances avec Zabbix.
- Couche sécurité et SIEM : détection d'intrusions et analyse des journaux avec Wazuh.
- Couche visualisation : tableaux de bord opérationnels avec Grafana.

4.2 Environnement de virtualisation – VMware

L'environnement de déploiement repose sur VMware, plateforme de virtualisation de référence largement utilisée dans les datacenters bancaires. VMware permet la création et la gestion d'un ensemble de machines virtuelles partageant les ressources physiques d'un ou plusieurs hyperviseurs, simulant ainsi un Cloud privé d'entreprise.

Ce choix technologique présente plusieurs avantages dans le contexte de ce projet :

- Isolation des machines virtuelles garantissant la sécurité des environnements.
- Flexibilité dans l'allocation des ressources (CPU, RAM, stockage).
- Facilité de création de snapshots pour la restauration en cas d'incident.
- Possibilité de simuler une segmentation réseau réaliste via des vLAN virtuels.
- Compatibilité avec les configurations réseau avancées nécessaires pour pfSense.

4.3 Description des machines virtuelles

L'infrastructure déployée comprend cinq machines virtuelles aux rôles distincts, représentant les composantes types d'un système d'information bancaire :

VM	Nom	OS	Rôle	Outils installés
VM1	Client	Windows 10	Poste utilisateur (employé banque)	Agent Wazuh, Agent Zabbix
VM2	Alma	Ubuntu Server	Serveur central SOC	Wazuh Server, Zabbix Server, Grafana

VM	Nom	OS	Rôle	Outils installés
VM3	Db-server	Ubuntu 22.04	Serveur base de données	MySQL/MariaDB, Agent Wazuh, Agent Zabbix
VM4	Web-server	Ubuntu 22.04	Serveur web applicatif bancaire	Apache2, Agent Wazuh, Agent Zabbix
VM5	Ubuntu-client	Ubuntu 22.04	Poste administrateur	Agent Wazuh, outils d'administration

4.3.1 VM1 – Poste client Windows

Cette machine virtuelle représente le poste de travail d'un employé de banque. Elle est utilisée pour simuler les interactions quotidiennes avec les systèmes bancaires : connexions aux applications métier, accès aux ressources partagées, consultation de messagerie. Elle permet également de simuler des scénarios de menaces internes ou de compromission d'un poste utilisateur.

L'agent Wazuh installé sur ce poste remonte en temps réel tous les événements de sécurité : tentatives de connexion, modifications de la base de registre, création de processus suspects, connexions réseau anormales.

4.3.2 VM2 – Serveur Alma (Centre SOC)

Cette machine constitue le cœur de l'infrastructure SOC. Elle héberge l'ensemble des serveurs de supervision et de sécurité.

Le serveur Alma concentre trois services critiques :

- Le serveur Wazuh : collecte et analyse les journaux de l'ensemble des agents déployés.
- Le serveur Zabbix : reçoit les métriques de performance de toutes les machines supervisées.
- Grafana : interroge les données de Zabbix et présente les tableaux de bord opérationnels.

4.3.3 VM3 – Serveur de base de données

Le serveur db-server héberge la base de données centrale de la banque simulée. Dans un contexte réel, ce serveur stockerait les données clients, les transactions financières, les soldes de comptes et les informations personnelles des données particulièrement sensibles au regard du RGPD et de PCI-DSS. Il constitue donc l'actif le plus critique de l'infrastructure et la cible prioritaire des attaquants.

La supervision de ce serveur inclut le monitoring des performances de la base de données, des connexions entrantes, des requêtes anormalement longues et des accès non autorisés.

4.3.4 VM4 – Serveur web applicatif

Le serveur web-server héberge l'application bancaire accessible aux clients via un navigateur. Il fait tourner un serveur Apache2 et représente la face exposée de l'infrastructure bancaire. C'est par ce vecteur que transitent les requêtes des clients pour consulter leurs comptes, effectuer des virements ou accéder aux services financiers.

Ce serveur est particulièrement exposé aux attaques de type injection SQL, Cross-Site Scripting (XSS), traversée de répertoire et déni de service. Sa surveillance par Wazuh permet de détecter ces tentatives en analysant les journaux Apache.

4.3.5 VM5 – Poste administrateur

La machine ubuntu-client représente le poste de travail de l'administrateur système. Elle est utilisée pour la gestion des serveurs, la configuration des outils, le diagnostic des incidents et la réalisation des tests de sécurité. Sa surveillance est importante car les comptes administrateurs sont des cibles privilégiées des attaquants cherchant à obtenir des privilèges élevés sur le système.

4.4 Sécurité réseau – pfSense

La segmentation et la sécurisation du réseau sont assurées par pfSense, solution de pare-feu et de routage open source basée sur FreeBSD. PfSense est largement utilisé dans les PME et les datacenters comme solution de sécurité périmétrique et interne.

Dans le cadre de ce projet, pfSense remplit plusieurs fonctions essentielles :

- Filtrage des flux entrants et sortants selon des règles définies par zone de confiance.
- Segmentation logique du réseau en zones distinctes (zone utilisateurs, zone serveurs, zone supervision, zone DMZ).
- Journalisation des connexions réseau et export des logs vers Wazuh pour corrélation.
- Protection contre les scans de ports et les tentatives de reconnaissance réseau.
- Contrôle des protocoles autorisés entre les différentes zones.

Cette segmentation respecte le principe de défense en profondeur (Defense in Depth) et le modèle Zero Trust : aucun flux n'est autorisé par défaut, chaque communication doit être explicitement autorisée.

5. Outils déployés et configuration

5.1 Wazuh – SIEM et détection d'intrusions

5.1.1 Présentation de Wazuh

Wazuh est une plateforme de sécurité open source qui intègre plusieurs fonctionnalités essentielles pour un SOC. Initialement fork d'OSSEC (Open Source HIDS Security), Wazuh a évolué pour devenir une solution complète de détection et de réponse aux menaces, maintenant avec le soutien d'une communauté active et d'une entreprise commerciale.

Wazuh se distingue par son architecture modulaire comprenant :

- Un serveur central (Wazuh Manager) qui reçoit, analyse et corrèle les événements.
- Des agents légers déployés sur les machines supervisées, qui collectent et transmettent les journaux.
- Une interface web (Wazuh Dashboard) basée sur OpenSearch pour la visualisation des alertes.
- Un moteur de règles configurable permettant de personnaliser les seuils de détection.

5.1.2 Fonctionnalités utilisées dans ce projet

Dans le cadre du POC, les modules suivants de Wazuh ont été exploités :

Module Wazuh	Fonction	Application dans le projet
Log Analysis	Collecte et analyse des journaux système	Surveillance de tous les serveurs (syslog, auth.log, Apache access.log)
Intrusion Detection	Détection de comportements suspects	Alertes sur tentatives de connexion anormales
File Integrity Monitoring (FIM)	Surveillance de l'intégrité des fichiers	Détection de création/modification de fichiers système critiques
Vulnerability Detection	Identification des vulnérabilités connues	Scan des packages installés
Security Configuration Assessment	Évaluation de la conformité des configurations	Vérification des bonnes pratiques de hardening

5.1.3 Architecture de déploiement Wazuh

Le serveur Wazuh est déployé sur la machine alma (VM2). Les agents Wazuh sont installés sur toutes les autres machines virtuelles. La communication entre les agents et le serveur s'effectue via le protocole OSSEC sur le port 1514 (UDP) et 1515 (TCP) pour l'enregistrement des agents.

La configuration des agents inclut notamment :

- La définition des répertoires à surveiller en File Integrity Monitoring (répertoires système, fichiers de configuration critiques).
- La configuration des intervalles de collecte et de transmission des journaux.
- La définition des règles de détection spécifiques à l'environnement bancaire.

5.2 Zabbix – Supervision d'infrastructure

5.2.1 Présentation de Zabbix

Zabbix est une solution open source de monitoring d'infrastructure réseau et système, développée depuis 2001 et aujourd'hui utilisée par des milliers d'organisations à travers le monde, y compris dans le secteur bancaire et financier. Sa robustesse, sa scalabilité et sa richesse fonctionnelle en font l'outil de référence pour la supervision d'environnements critiques.

Zabbix permet de collecter des métriques depuis des sources variées :

- Agents Zabbix installés sur les serveurs (collecte des métriques système détaillées).
- SNMP pour les équipements réseau (switches, routeurs).
- ICMP pour la vérification de la disponibilité réseau (ping).
- Checks externes via scripts personnalisés pour des métriques applicatives.

5.2.2 Métriques supervisées

Dans le cadre du projet, Zabbix supervise les métriques suivantes sur chaque machine virtuelle :

Catégorie	Métriques collectées	Seuils d'alerte
CPU	Utilisation CPU totale, par processus, charge système	> 80% pendant > 5 min
Mémoire	RAM utilisée/libre, swap, cache	> 90% utilisation RAM
Disque	Espace utilisé, I/O read/write, latence	> 85% espace utilisé
Réseau	Bande passante entrante/sortante, erreurs, paquets perdus	> 80% de la capacité
Services	État des services critiques (SSH, Apache, MySQL)	Service arrêté
Disponibilité	Ping, réponse des services, uptime	Non-réponse > 1 min

5.2.3 Système d'alertes Zabbix

Zabbix est configuré pour générer des alertes selon un système de sévérité à plusieurs niveaux (Information, Warning, Average, High, Disaster). En cas de franchissement d'un seuil, une action est déclenchée automatiquement, pouvant inclure l'envoi d'une notification (email, SMS, webhook) ou l'exécution d'un script de remédiation.

5.3 Grafana – Visualisation et tableaux de bord

5.3.1 Présentation de Grafana

Grafana est un outil de visualisation et d'analyse de données open source, devenu une référence mondiale pour la création de tableaux de bord opérationnels. Il se connecte à de multiples sources de données via des plugins (Zabbix, Prometheus, Elasticsearch, InfluxDB, MySQL, etc.) et permet de créer des visualisations riches et interactives.

Dans le contexte d'un SOC bancaire, Grafana remplit un rôle essentiel : il transforme des données brutes et techniques en informations actionnables pour les différents profils d'utilisateurs, techniciens, managers, RSSI.

5.3.2 Tableaux de bord configurés

Plusieurs tableaux de bord ont été configurés dans le cadre du POC :

- Dashboard Infrastructure Overview : vue globale de l'état de toutes les machines virtuelles (disponibilité, CPU, RAM, disque).
- Dashboard Sécurité : visualisation des alertes Wazuh, nombre d'événements par machine, cartographie des tentatives d'accès.
- Dashboard Performances : évolution temporelle des métriques système, identification des tendances.
- Dashboard Disponibilité des Services : état en temps réel de chaque service critique (web, base de données, authentification).

L'intégration de Grafana avec Zabbix est réalisée via le plugin officiel Grafana-Zabbix, qui permet d'interroger directement l'API de Zabbix pour récupérer les métriques et les événements.

6. Réalisation du POC

6.1 Démarche de déploiement

La mise en place du POC a suivi une démarche structurée en plusieurs phases successives, chacune validée avant de passer à la suivante :

1. Préparation de l'environnement VMware : création des machines virtuelles, configuration réseau, attribution des rôles.
2. Installation du serveur central SOC (alma) : déploiement de Wazuh Manager, Zabbix Server et Grafana.
3. Déploiement des agents sur les machines supervisées : installation et enregistrement des agents Wazuh et Zabbix sur VM1, VM3, VM4 et VM5.
4. Configuration de pfSense : définition des règles de filtrage et de la segmentation réseau.
5. Configuration des tableaux de bord Grafana : création des visualisations et connexion aux sources de données.
6. Réalisation des tests de sécurité : exécution des scénarios d'attaque et validation de la détection.

6.2 Difficultés rencontrées et solutions apportées

Le déploiement de cette architecture a présenté plusieurs défis techniques qui ont nécessité une analyse approfondie et une résolution méthodique. Ces difficultés, bien que contraignantes, ont constitué une expérience pédagogique précieuse, reflétant la réalité des déploiements en production.

6.2.1 Problème 1 – Agents Wazuh non connectés

Au démarrage du déploiement, plusieurs agents Wazuh apparaissaient en état Disconnected dans le tableau de bord. Malgré l'installation correcte des packages, les agents ne parvenaient pas à établir la communication avec le serveur Wazuh.

Analyse et résolution

Cause identifiée : Des erreurs de configuration des adresses IP dans les fichiers ossec.conf des agents.

Également : Des règles de pare-feu pfSense bloquaient le port 1514 (communication Wazuh).

Solution : Vérification et correction des adresses IP de configuration, ouverture des ports Wazuh dans pfSense,

Redémarrage séquentiel des services (wazuh-agent, puis wazuh-manager).

Enseignement : La rigueur dans la configuration réseau est primordiale dans un déploiement multi-VMs.

6.2.2 Problème 2 – Serveurs affichés offline dans Grafana

Après la connexion du plugin Grafana-Zabbix, le tableau de bord affichait l'ensemble des serveurs dans un état OFFLINE, bien que Zabbix reçoive des données en interne. Aucune métrique n'était visible dans les graphiques.

Analyse et résolution

Cause identifiée : Mauvaise configuration des paramètres d'authentification de l'API Zabbix dans Grafana.

L'URL de l'API était également mal renseignée (absence du suffixe /api_jsonrpc.php).

Outil de diagnostic utilisé : zabbix_get pour tester la communication directe entre le serveur et les agents.

Solution : Correction de l'URL API, régénération du token d'authentification Zabbix, redémarrage de Grafana.

Validation : Test de chaque source de données Grafana avant configuration des tableaux de bord.

6.2.3 Problème 3 – Conflits d'identifiants à la suite du clonage de VMs

Le clonage de machines virtuelles sous VMware pour accélérer le déploiement a provoqué des conflits d'identifiants dans Wazuh. Les machines clonées conservaient le même UUID d'agent, ce qui empêchait leur enregistrement individuel sur le serveur.

Analyse et résolution

Cause identifiée : Les agents Wazuh utilisent un identifiant unique (agent-id) généré lors de l'installation.

Le clonage de VMs copie cet identifiant, créant des doublons qui empêchent l'enregistrement.

Solution : Suppression des entrées dupliquées dans la base Wazuh (/var/ossec/queue/db/),

Suppression des fichiers client.keys sur les VMs clonées, réenregistrement des agents.

Bonne pratique adoptée : Toujours désenregistrer un agent Wazuh avant de cloner une VM.

7. Tests de sécurité et validation du POC

7.1 Méthodologie de test

Pour valider l'efficacité du SOC déployé, trois scénarios d'attaque représentatifs des menaces réelles pesant sur le secteur bancaire ont été simulés. Chaque test a suivi la méthodologie suivante :

7. Définition du scénario : description de l'attaque, de l'attaquant simulé et de l'objectif.
8. Exécution de l'attaque depuis la machine ubuntu-client (poste administrateur).
9. Observation en temps réel du tableau de bord Grafana et du dashboard Wazuh.
10. Analyse des alertes générées et validation de la détection.
11. Documentation des résultats et des indicateurs de détection.

7.2 Test 1 – Attaque par force brute SSH

7.2.1 Description du scénario

L'attaque par force brute SSH (Secure Shell) consiste à tenter de nombreuses combinaisons de noms d'utilisateur et de mots de passe pour accéder à un serveur à distance. C'est l'une des attaques les plus fréquentes contre les serveurs Linux exposés sur un réseau, et l'une des premières tentatives d'un attaquant cherchant à obtenir un accès initial.

Dans le contexte bancaire, la compromission d'un accès SSH sur un serveur critique pourrait permettre à un attaquant d'accéder à la base de données, de modifier des fichiers de configuration, de créer des comptes backdoor ou d'exfiltrer des données sensibles.

7.2.2 Exécution du test

L'attaque a été simulée depuis la machine ubuntu-client en effectuant de multiples tentatives de connexion SSH avec des identifiants incorrects sur le serveur db-server (VM3). Le nombre de tentatives échouées (supérieur au seuil de détection Wazuh configuré à 5 tentatives en moins d'une minute) a déclenché la chaîne de détection.

7.2.3 Résultats et analyse

Indicateur	Valeur obtenue
Délai de détection (MTTD)	< 30 secondes
Niveau d'alerte Wazuh	Level 10 – Multiple failed logins
Règle déclenchée	Règle 5503 – sshd: authentication failure
Logs collectés	Oui – /var/log/auth.log analysé en temps réel
Alerte visible dans Grafana	Oui – compteur d'événements incrémenté

Indicateur	Valeur obtenue
Action automatique	Génération d'alerte dans le dashboard Wazuh

Ce test démontre la capacité du SOC à détecter rapidement une tentative d'intrusion par force brute, avec un temps de détection inférieur à 30 secondes. Dans un environnement de production, cette alerte déclencherait l'intervention d'un analyste SOC et pourrait activer un blocage automatique de l'adresse IP source via un script de remédiation.

7.3 Test 2 – Surveillance d'intégrité des fichiers (FIM)

7.3.1 Description du scénario

Le File Integrity Monitoring (FIM) est une technique de sécurité fondamentale qui consiste à surveiller en temps réel les modifications apportées aux fichiers critiques d'un système. Dans un contexte bancaire, tout fichier modifié sans autorisation peut signaler une compromission : altération de fichiers de configuration, création d'une backdoor, implantation d'un malware, modification des logs pour effacer des traces.

Ce test simule la création d'un fichier suspect dans un répertoire critique du système qui est une action typique d'un attaquant ayant obtenu un accès et cherchant à maintenir sa persistance.

7.3.2 Exécution du test

Un fichier nommé `hack_banque.txt` a été créé dans le répertoire `/etc/` de la machine `db-server` en utilisant des privilèges `sudo`, afin de simuler une action d'un utilisateur ayant escaladé ses privilèges. Le module FIM de Wazuh surveille ce répertoire en temps réel.

7.3.3 Résultats et analyse

Indicateur	Valeur obtenue
Délai de détection (MTTD)	< 5 secondes
Niveau d'alerte Wazuh	Level 7 – Integrity checksum changed
Règle déclenchée	Règle 550 – File added to the system
Éléments détectés	Création du fichier + utilisation de <code>sudo</code>
Chemin surveillé	<code>/etc/hack_banque.txt</code>
Alerte visible dans Dashboard	Oui – alerte FIM avec métadonnées complètes

Ce test valide la capacité du SOC à détecter non seulement la création du fichier, mais également l'utilisation de `sudo` qui accompagne l'action fournissant ainsi une contextualisation précieuse pour l'analyste SOC. Dans un environnement réel, cette détection permettrait d'identifier un mouvement latéral ou une tentative de persistance en moins de 5 secondes.

7.4 Test 3 – Simulation d'attaque web

7.4.1 Description du scénario

Les applications web bancaires sont constamment exposées à des tentatives d'attaque : injections SQL visant la base de données clients, traversées de répertoire cherchant à accéder à des fichiers de configuration, tentatives d'accès à des ressources d'administration non protégées. Ce test simule l'envoi d'une requête HTTP malveillante vers le serveur web applicatif.

7.4.2 Exécution du test

Une requête HTTP malveillante a été construite et envoyée vers le serveur web (VM4 web-server) depuis la machine ubuntu-client. La requête cible un chemin caractéristique d'une tentative de traversée de répertoire (path traversal). Bien que le serveur Apache ait répondu avec un code d'erreur HTTP 404 (ressource non trouvée), l'événement a été enregistré dans les journaux d'accès Apache et analysé par Wazuh.

7.4.3 Résultats et analyse

Indicateur	Valeur obtenue
Délai de détection (MTTD)	< 10 secondes
Source de log analysée	/var/log/apache2/access.log
Règle Wazuh déclenchée	Règle 31101 – Web attack detected
Réponse du serveur	HTTP 404 (path not found)
Alerte générée	Oui – avec IP source, URL cible et timestamp
Corrélation multi-sources	Log Apache + Log système corrélés

Ce test démontre un aspect crucial de la valeur ajoutée d'un SIEM : même lorsqu'une attaque échoue techniquement (le serveur renvoie une erreur 404), elle est néanmoins détectée et enregistrée. Cette capacité permet aux analystes SOC de suivre les tentatives de reconnaissance et d'identifier des patterns d'attaque avant qu'une tentative réussisse.

8. Résultats et bilan du POC

8.1 Synthèse des résultats obtenus

À l'issue du déploiement et des tests de validation, les résultats suivants ont été obtenus :

Objectif	Statut	Commentaire
5 VMs connectées au SOC	✓ Atteint	Toutes les machines supervisées par Wazuh et Zabbix
Supervision temps réel	✓ Atteint	Métriques CPU, RAM, disques disponibles en continu
Détection brute force SSH	✓ Atteint	Détection en < 30 secondes
Surveillance intégrité fichiers	✓ Atteint	Détection en < 5 secondes
Détection attaque web	✓ Atteint	Log Apache analysé et alerte générée
Tableaux de bord Grafana	✓ Atteint	Dashboards opérationnels configurés
Segmentation réseau pfSense	✓ Atteint	Règles de filtrage configurées
Centralisation des logs	✓ Atteint	Tous les journaux agrégés sur alma

8.2 Indicateurs de performance clés

Les indicateurs de performance mesurés pendant les tests témoignent de l'efficacité de l'architecture déployée :

KPI	Valeur mesurée	Référence industrie
Mean Time to Detect (MTTD) – Brute force	< 30 secondes	< 1 minute (excellent)
Mean Time to Detect (MTTD) – FIM	< 5 secondes	< 30 secondes (excellent)
Taux de détection des scénarios testés	100% (3/3)	> 95% (objectif SOC)
Disponibilité de la plateforme SOC	100% (pendant les tests)	> 99.9% (objectif)
Couverture de supervision	5/5 VMs	100% de l'infrastructure

8.3 Valeur ajoutée de la solution

Au-delà des aspects purement techniques, ce POC démontre une valeur ajoutée significative pour un établissement bancaire, mesurable selon plusieurs axes :

8.3.1 Réduction du risque financier

Le coût moyen d'une violation de données dans le secteur financier est estimé à plusieurs millions d'euros (selon les rapports annuels d'IBM Cost of a Data Breach). La détection précoce des attaques permet de réduire drastiquement ce coût. Un MTTD de 30 secondes versus un délai de détection moyen de 207 jours (chiffre industrie sans SOC) représente une réduction du risque considérable.

8.3.2 Conformité réglementaire

La plateforme répond directement aux exigences réglementaires suivantes, réduisant le risque de sanctions :

- DORA : surveillance continue et capacité de détection des incidents TIC.
- PCI-DSS : journalisation complète et surveillance des accès (exigences 10 et 11).
- RGPD : capacité de détecter rapidement toute violation de données personnelles.

8.3.3 Retour sur investissement (ROI)

L'utilisation exclusive d'outils open source (Wazuh, Zabbix, Grafana, pfSense) permet de construire une architecture SOC de niveau professionnel à un coût d'infrastructure minimal, l'investissement principal étant humain (formation, configuration, exploitation). Pour une banque de taille moyenne, cette approche peut représenter une économie de plusieurs centaines de milliers d'euros par rapport à des solutions commerciales équivalentes (Splunk Enterprise, IBM QRadar, etc.).

9. Limites, améliorations et perspectives

9.1 Limites du POC

Ce proof of concept, bien que démontrant la faisabilité et l'efficacité du concept, présente des limites inhérentes à son périmètre :

- Environnement simulé : L'infrastructure repose sur des machines virtuelles locales, sans exposition à un vrai réseau bancaire avec ses contraintes de charge, de latence et de complexité.
- Volume de données limité : Les tests ont été réalisés avec un faible nombre de machines et d'événements. En production, un SOC bancaire traite des millions d'événements par jour.
- Absence de SOAR : La détection est validée, mais la réponse automatisée aux incidents (Security Orchestration, Automation and Response) n'a pas été implémentée.
- Couverture des menaces : Seuls trois scénarios d'attaque ont été testés. Un SOC réel fait face à des centaines de types de menaces différents.
- Absence de Threat Intelligence : L'architecture ne dispose pas de flux de renseignements sur les menaces (IOC, TTPs) qui permettraient d'enrichir la détection.

9.2 Axes d'amélioration à court terme

Plusieurs améliorations pourraient être apportées rapidement pour renforcer le POC :

- Intégration de MITRE ATT&CK : Aligner les règles de détection Wazuh avec le framework MITRE ATT&CK pour le secteur financier (FS-ISAC).
- Déploiement d'un IPS : Compléter l'IDS Wazuh par un système de prévention d'intrusion (Suricata) pour bloquer automatiquement les attaques détectées.
- Enrichissement des alertes : Intégration de flux de Threat Intelligence open source (MISP, OpenCTI) pour contextualiser les IOC (Indicators of Compromise).
- Automatisation de la réponse : Création de playbooks automatisés (via Shuffle ou TheHive) pour les incidents récurrents (blocage IP, isolation de machine).
- Hardening des systèmes : Application des recommandations CIS Benchmarks sur les machines virtuelles pour réduire la surface d'attaque.

9.3 Perspectives à moyen terme

Dans une optique de déploiement réel en environnement bancaire, les évolutions suivantes sont envisageables :

- Migration vers un Cloud public : Adaptation de l'architecture pour un déploiement sur AWS, Azure ou GCP, avec utilisation des services natifs (CloudTrail, Azure Sentinel, Google Chronicle).

- Mise en conformité DORA complète : Formalisation des processus de gestion des incidents TIC, tests de résilience TLPT (Threat-Led Penetration Testing), rapportage aux autorités.
- Déploiement d'un EDR : Intégration d'un Endpoint Detection and Response (Velociraptor, Wazuh EDR) pour améliorer la visibilité sur les postes de travail.
- Analyse comportementale (UEBA) : Ajout d'un module d'analyse comportementale des utilisateurs pour détecter les menaces internes et les comptes compromis.
- Centre de supervision H24 : Formation d'une équipe SOC et définition des processus d'escalade et d'astreinte.

9.4 Scalabilité de l'architecture

L'architecture proposée est conçue pour être scalable. Zabbix et Wazuh supportent tous deux des déploiements à grande échelle avec des architectures distribuées (Zabbix Proxy, Wazuh Cluster). Grafana peut être connecté à des dizaines de sources de données et supporte des milliers d'utilisateurs simultanés. L'ajout de nouvelles machines à superviser se fait simplement par l'installation de l'agent correspondant, sans modification de l'architecture centrale.

10. Conclusion

Ce projet de Proof of Concept a permis de démontrer avec succès la faisabilité d'une plateforme centralisée de supervision et de monitoring de la sécurité pour une infrastructure bancaire hébergée dans un environnement virtualisé. En mobilisant exclusivement des outils open source reconnus (Wazuh, Zabbix, Grafana, pfSense) sur une infrastructure VMware, nous avons construit un démonstrateur fonctionnel d'architecture SOC capable de répondre aux exigences opérationnelles et réglementaires du secteur financier.

Les résultats obtenus sont probants : 100% des scénarios d'attaque simulés ont été détectés, avec des délais de détection excellents (inférieurs à 30 secondes pour les attaques de connexion, inférieurs à 5 secondes pour les altérations de fichiers). La plateforme offre une visibilité complète sur l'état de l'infrastructure en temps réel et centralise l'ensemble des journaux de sécurité pour faciliter l'analyse forensique.

Au-delà de l'aspect technique, ce projet illustre un principe fondamental de la cybersécurité moderne : la détection précoce est la meilleure défense. Dans un secteur bancaire où chaque seconde de compromission non détectée peut se traduire par des pertes financières et des violations de données aux conséquences réglementaires considérables, investir dans un SOC est une nécessité stratégique autant qu'une obligation de conformité.

L'architecture proposée s'inscrit pleinement dans les exigences réglementaires actuelles (DORA, PCI-DSS, RGPD) et constitue une base solide pour un déploiement progressif en production. Elle démontre qu'il est possible de construire un système de supervision de niveau professionnel avec des solutions open source, rendant cette approche accessible à des établissements financiers de toutes tailles.

Ce projet nous a également confrontés à des défis techniques concrets : conflits d'identifiants, problèmes de connectivité, configuration des API dont la résolution a renforcé notre compréhension des enjeux opérationnels d'un déploiement SOC en conditions réelles. Ces expériences constituent un acquis précieux pour nos futures responsabilités professionnelles dans le domaine de la cybersécurité.

Points clés à retenir

- ✓ Architecture SOC fonctionnelle déployée avec des outils open source de niveau professionnel.
- ✓ Détection validée de 3 scénarios d'attaque avec un MTTD < 30 secondes.
- ✓ Conformité aux exigences DORA, PCI-DSS et RGPD démontrée.
- ✓ Scalabilité de l'architecture validée pour un déploiement en production.
- ✓ Coût d'infrastructure minimal grâce à l'utilisation exclusive d'outils open source.

11. Glossaire

Terme	Définition
ACPR	Autorité de Contrôle Prudentiel et de Résolution – régulateur bancaire français.
DORA	Digital Operational Resilience Act – règlement européen sur la résilience numérique des entités financières (2022/2554).
EDR	Endpoint Detection and Response – solution de détection et réponse sur les postes de travail et serveurs.
FIM	File Integrity Monitoring – surveillance de l'intégrité des fichiers système en temps réel.
IDS	Intrusion Detection System – système de détection d'intrusions réseau ou hôte.
IPS	Intrusion Prevention System – système de prévention d'intrusions, bloquant activement les attaques.
IOC	Indicator of Compromise – indicateur permettant d'identifier une compromission (hash, IP, domaine).
KPI	Key Performance Indicator – indicateur clé de performance permettant de mesurer l'efficacité d'un système.
MITRE ATT&CK	Framework de référence décrivant les tactiques, techniques et procédures des attaquants.
MTTD	Mean Time to Detect – temps moyen entre le début d'une attaque et sa détection.
MTTR	Mean Time to Respond – temps moyen entre la détection d'un incident et sa résolution.
PCI-DSS	Payment Card Industry Data Security Standard – norme de sécurité pour les environnements de paiement par carte.
POC	Proof of Concept – démonstration de faisabilité d'un concept ou d'une technologie.
RGPD	Règlement Général sur la Protection des Données – règlement européen sur la protection des données personnelles.
RSSI	Responsable de la Sécurité des Systèmes d'Information – responsable de la politique de cybersécurité.
SIEM	Security Information and Event Management – solution de collecte, corrélation et analyse des événements de sécurité.
SNMP	Simple Network Management Protocol – protocole de supervision réseau.
SOC	Security Operations Center – centre de surveillance et de réponse aux incidents de cybersécurité.
SOAR	Security Orchestration, Automation and Response – solution d'automatisation de la réponse aux incidents.

Terme	Définition
SSH	Secure Shell – protocole de connexion sécurisée à distance sur les serveurs Unix/Linux.
UEBA	User and Entity Behavior Analytics – analyse comportementale des utilisateurs pour détecter les menaces internes.
VM	Virtual Machine – machine virtuelle, instance logicielle simulant un ordinateur physique.
VMware	Éditeur de logiciels de virtualisation, fournissant des hyperviseurs pour créer et gérer des machines virtuelles.
Wazuh	Solution open source de SIEM et de détection d'intrusions, intégrant FIM, analyse de logs et évaluation de conformité.
Zabbix	Solution open source de monitoring d'infrastructure réseau et système.
Zero Trust	Modèle de sécurité basé sur le principe 'ne jamais faire confiance, toujours vérifier'.

12. Bibliographie et références

12.1 Réglementation et normes

- Règlement (UE) 2022/2554 du Parlement européen et du Conseil du 14 décembre 2022 sur la résilience opérationnelle numérique du secteur financier (DORA).
- PCI Security Standards Council – PCI DSS v4.0, mars 2022.
- Règlement (UE) 2016/679 (RGPD) – Règlement général sur la protection des données.
- ENISA – Threat Landscape for Financial Institutions, 2023.
- Banque de France / ACPR – Recommandations en matière de cybersécurité pour les établissements financiers.

12.2 Documentation technique

- Documentation officielle Wazuh – <https://documentation.wazuh.com>
- Documentation officielle Zabbix – <https://www.zabbix.com/documentation>
- Documentation officielle Grafana – <https://grafana.com/docs>
- Documentation pfSense – <https://docs.netgate.com>
- MITRE ATT&CK Framework – <https://attack.mitre.org>

12.3 Publications et rapports

- IBM Security – Cost of a Data Breach Report 2023.
- Verizon – Data Breach Investigations Report (DBIR) 2023.
- SANS Institute – SOC Survey 2023 : Building a World-Class Security Operations Center.
- Gartner – Market Guide for Security Information and Event Management (SIEM), 2023.